

ROAD TO HALL OF FAME - ACTIVIDAD 11

FILE PATH TRAVERSAL, VALIDATION OF START OF PATH

Mtro. Servando López Contreras

Informe realizado por:

181583 Angel Aaron Acuña Quezada

Contenido

Datos del Laboratorio	3
Marco Teórico y Fundamentación Técnica	3
Procedimiento	4
Explicación del Payload	6
Mitigación Recomendada.....	6
Referencias	7

Datos del Laboratorio

- **Nombre del laboratorio:** *File path traversal, validation of start of path*
- **Nivel:** Practitioner
- **Tipo de Explotación:** File Path Traversal
- **Objetivo del laboratorio:** Explorar la vulnerabilidad de File Path Traversal a través del método de petición "GET" del protocolo HTTP, con el fin de poder leer el archivo `/etc/passwd`.

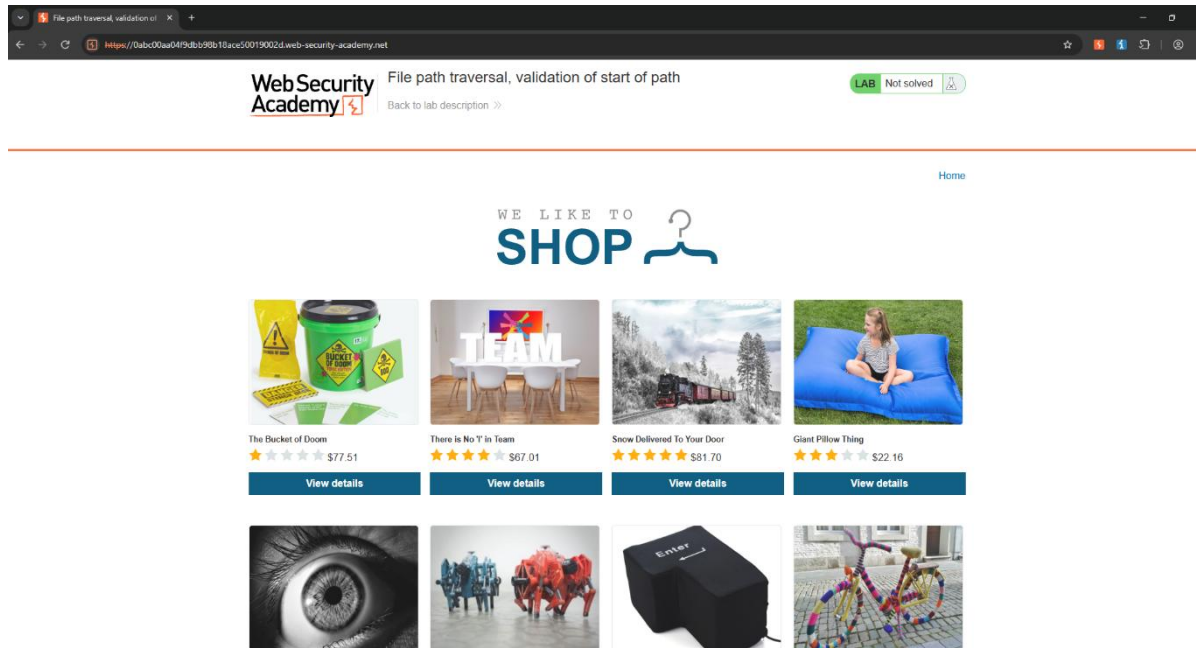
Marco Teórico y Fundamentación Técnica

Concepto: De acuerdo con OWASP, un ataque de *Path Traversal* (también conocido como *Directory Traversal*) tiene como objetivo acceder a archivos y directorios que están almacenados fuera de la carpeta raíz web. Al manipular las variables que hacen referencia a los archivos usando secuencias de "punto-punto-barra" (`../`) o rutas absolutas permite a un atacante acceder a archivos y directorios en el sistema de archivos, incluyendo código fuente de la aplicación, configuraciones y archivos críticos del sistema. En el caso particular de este laboratorio, la aplicación transmite la ruta completa del archivo a través del parámetro `filename` (por ejemplo, `/var/www/images/50.jpg`) y valida únicamente que dicha ruta **comience** con la carpeta esperada (`/var/www/images/`). Sin embargo, no verifica el resto de la ruta después de ese prefijo, por lo que es posible añadir secuencias de traversal justo después del directorio validado para escapar de él y acceder a archivos arbitrarios del sistema.

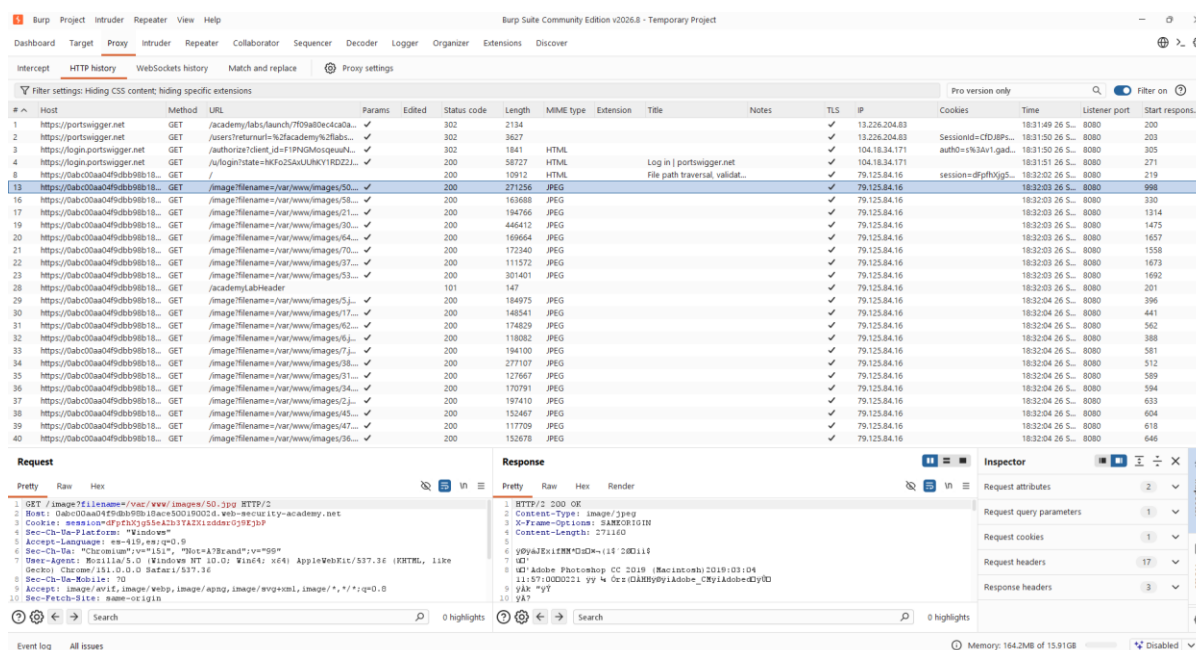
Impacto en la Triada CIA: Esta vulnerabilidad compromete de manera directa la "Confidencialidad" de la información, ya que expone datos sensibles del sistema operativo.

Perspectiva OWASP: Clasificada dentro de la categoría de *Broken Access Control* (Control de Acceso Roto), ocurre cuando la aplicación utiliza la entrada del usuario para construir una ruta de archivo sin validar o sanear adecuadamente dicha entrada, permitiendo escapar de la estructura de directorios autorizada.

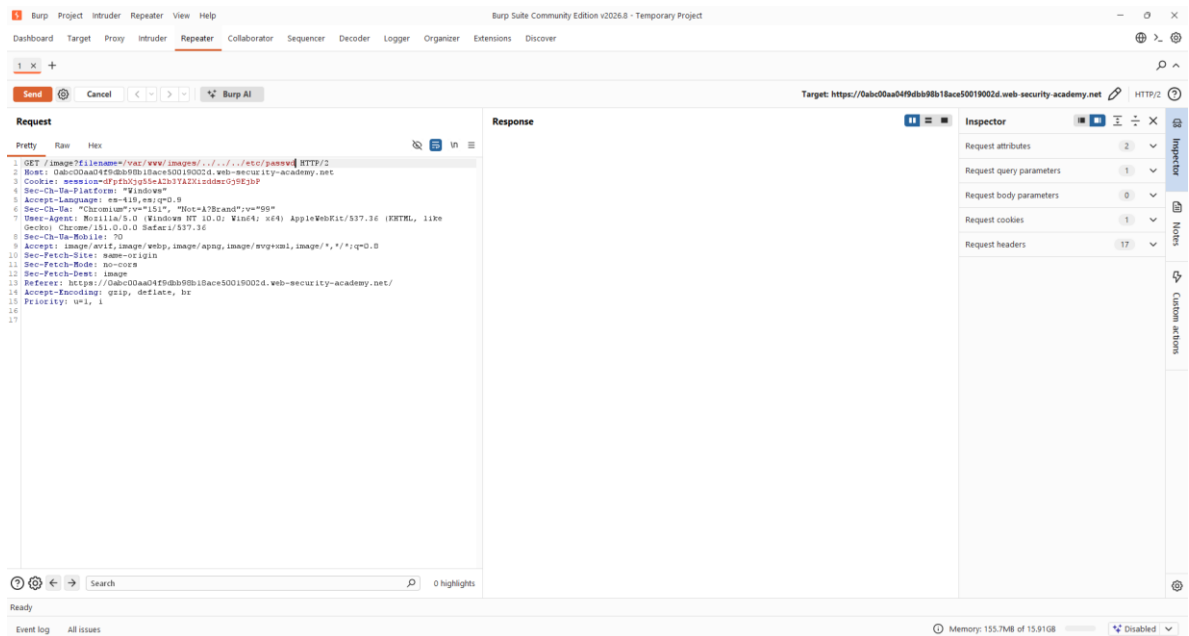
Procedimiento



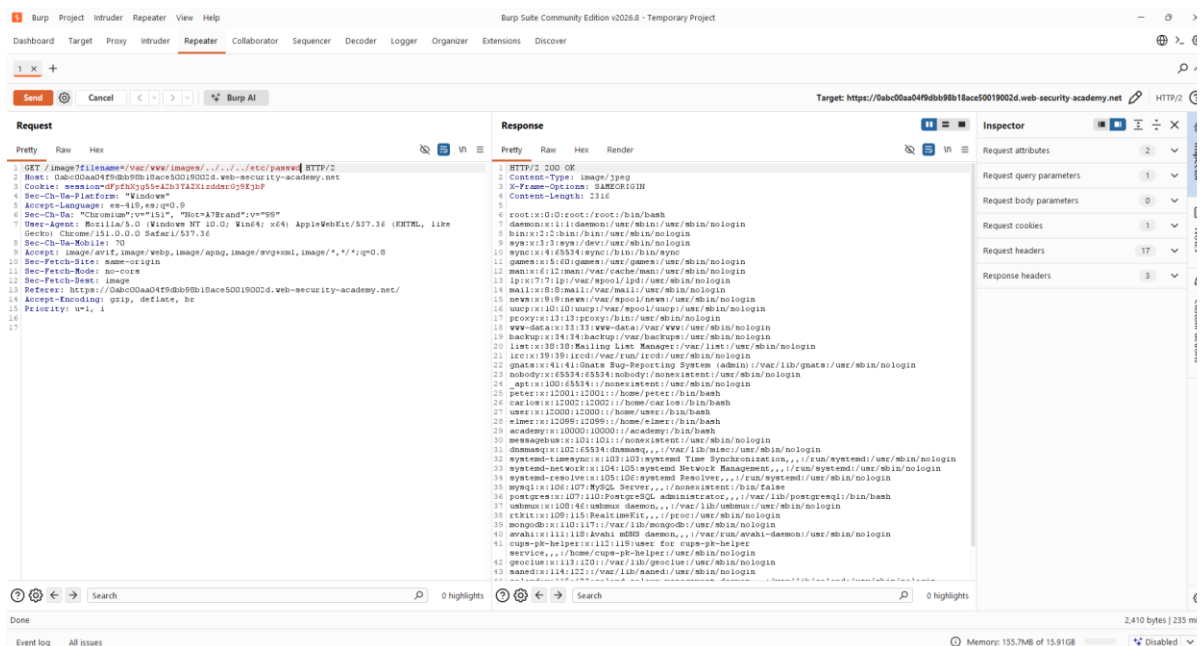
Se ingresó a la tienda virtual del laboratorio, en la cual podemos ver que carga varias imágenes de productos.



Durante la fase de reconocimiento en Burp Suite, se identificó que las peticiones GET hacia /image ya no envían únicamente el nombre del archivo, sino la ruta completa mediante el parámetro filename, por ejemplo filename=/var/www/images/50.jpg. Esto indica que la aplicación transmite la ruta absoluta al backend y valida su punto de partida.



Se envía la petición a 'Repeater' y se modifica el valor de filename, conservando el prefijo validado (`/var/www/images/`) pero agregando secuencias de traversal inmediatamente después: `/var/www/images/../../../../etc/passwd`. De esta forma, la validación de la aplicación se cumple porque la ruta sigue comenzando con el directorio esperado, pero al procesarse el sistema operativo resuelve las secuencias `../` y termina accediendo a `/etc/passwd`.



Damos clic en "Send" y podemos observar que tuvimos éxito y tenemos acceso al archivo `passwd`.

Explicación del Payload

El parámetro filename en este laboratorio no recibe solo el nombre de un archivo, sino una ruta completa. La aplicación valida que esta ruta comience con el directorio autorizado `/var/www/images/`, pero no analiza el contenido restante de la cadena. Al construir el payload `/var/www/images/../../../../etc/passwd`, la validación de prefijo se cumple satisfactoriamente, ya que la cadena efectivamente empieza con `/var/www/images/`. Sin embargo, una vez que el sistema operativo procesa la ruta completa, las secuencias `../` hacen que se ascienda tres niveles en la jerarquía de directorios, saliendo de la carpeta de imágenes y llegando hasta la raíz del sistema de archivos, desde donde se accede a `/etc/passwd`.

Mitigación Recomendada

- **Evitar entradas directas:** Lo más efectivo es evitar, lo más que se pueda, pasar la entrada directa al sistema de archivos. En su lugar, se podrían usar identificadores en una base de datos para localizar un archivo.
- **No validar solo el inicio de la ruta:** validar únicamente que una ruta comience con un directorio autorizado es insuficiente, ya que no impide que se agreguen secuencias de traversal después de ese prefijo. La validación debe aplicarse sobre la ruta ya resuelta (canonicalizada), no sobre la cadena cruda proporcionada por el usuario.
- **Canonicalización obligatoria antes de validar:** la aplicación debe resolver la ruta completa (usando funciones como `realpath()` o `os.path.abspath()`) antes de compararla con el directorio permitido. Solo así se garantiza que la ruta resultante realmente se encuentre dentro del directorio esperado, y no solo que comience con su nombre en texto plano.

Referencias

OWASP. (s.f.). *Path Traversal*. OWASP Community. Recuperado el 26 de septiembre de 2026, de https://community.owasp.org/attacks/Path_Traversal